

WebLine Company Cybersecurity and Privacy Policy Pack

Cybersecurity, privacy, and web application security policies.

Company: WebLine Company for Web Development

Document classification: Internal

Version: 1.0 | Date: 2026-05-12

This policy pack defines WebLine Company's cybersecurity and privacy requirements for web development, cloud hosting, client platforms, source code, production websites, support operations, and personal data processing.

All employees, contractors, and service providers supporting WebLine systems or client environments are required to follow the controls and responsibilities described in this document.

Policy Sections

1. Company Profile and Policy Scope

WebLine Company is a web development company that builds public websites, ecommerce portals, customer dashboards, APIs, and managed hosting environments for clients in Saudi Arabia and abroad.

This policy applies to employees, contractors, interns, cloud administrators, developers, designers, support staff, company laptops, source code repositories, CI/CD pipelines, production websites, staging environments, customer databases, analytics tools, and third-party SaaS services.

The General Manager and Head of Engineering approved this policy pack for internal use. The document is reviewed annually or after a major client incident, regulatory change, or material change to the cloud hosting architecture.

WebLine maintains client data in cloud platforms, managed database services, help desk software, analytics services, and source code repositories. The company processes business contact information, website user accounts, support tickets, payment integration metadata, IP addresses, logs, cookies, and limited client content.

2. Governance, Risk, and Accountability Policy

The Head of Engineering is the security owner for WebLine and reports cybersecurity status to the General Manager every quarter.

Security responsibilities are documented for the Head of Engineering, DevOps Lead, Development Team Leads, Project Managers, Support Engineers, Data Owners, and all employees.

WebLine maintains a cybersecurity risk register for production applications and client hosting environments. Risks are reviewed monthly by Engineering and Operations.

WebLine does not have a Board-approved cybersecurity risk appetite statement, formal risk tolerance thresholds, or key risk indicators approved by executive management.

Security exceptions can currently be approved by the Head of Engineering through a ticket comment. Some exceptions do not have an expiry date, compensating control, or documented business owner acceptance.

WebLine has not completed an independent cybersecurity audit during the last twelve months.

3. Asset Inventory and Data Classification Policy

WebLine maintains an inventory of production websites, cloud accounts, managed databases, DNS zones, domains, Git repositories, CI/CD pipelines, laptops, SaaS subscriptions, and privileged service accounts.

Each production system is assigned a system owner, environment classification, client owner, and criticality rating.

The inventory is updated from cloud exports, domain records, Git organization exports, and project onboarding records every month.

The inventory does not fully include shadow SaaS tools used by design and analytics teams, including some browser extensions, AI coding plugins, prototype tools, and ad-hoc client file sharing sites.

WebLine classifies information into Public, Internal, Client Confidential, Source Code, and Personal Data. Classification is complete for production customer databases and active Git repositories only.

Archived repositories, historical support tickets, analytics exports, and old project handover folders have not been fully classified or assigned retention owners.

4. Identity, Access, and Authentication Policy

All employees and contractors must use unique user IDs. Shared accounts are prohibited for production systems.

Multi-factor authentication is required for cloud consoles, source code repositories, VPN access, password vault access, production CMS admin panels, and CI/CD administrator accounts.

Access requests require approval from the employee manager and system owner before provisioning.

Privileged access to production cloud accounts is limited to DevOps engineers and is reviewed quarterly.

A shared staging administrator account named webline-stage-admin is still used for some legacy client CMS testing because the old staging platform does not support named accounts.

Contractor account removals are processed manually through service desk tickets. WebLine targets removal within ten business days after contract end, but the target is not consistently measured.

Non-critical SaaS access reviews are performed once per year. Some analytics, design, and project management tools are not included in the quarterly access review process.

Passwords must be at least 10 characters. The password standard blocks common passwords but does not require passphrases or a minimum of 12 characters for all systems.

5. Secure Software Development Life Cycle Policy

All production code changes require a pull request, peer review, successful build, and approval from a team lead before deployment.

WebLine uses branch protection for production repositories. Direct commits to the main branch are blocked for active repositories.

Static application security testing runs on the main branch for active client applications. Critical findings create tickets in the engineering backlog.

Threat modeling is performed only for high-risk ecommerce and authentication projects. Standard brochure websites and small admin portals usually do not receive documented threat models.

Dynamic application security testing is optional and is not required before every production release.

WebLine has not formally adopted OWASP ASVS as a mandatory application security standard across all projects.

Developers are instructed not to store secrets in source code. However, some legacy projects still use local .env files shared through project folders during onboarding.

Emergency changes may be approved in Slack during outages. Post-implementation review is expected but not consistently documented.

6. Web Application, API, and Website Security Policy

Production websites and APIs must use TLS 1.2 or higher. New projects use TLS 1.3 where supported by the hosting platform.

WebLine uses a Web Application Firewall for ecommerce portals, authentication portals, and high-traffic production websites.

Developers must validate user input server-side and use parameterized queries or approved ORM patterns for database access.

New applications must set Secure and HttpOnly attributes on session cookies.

Legacy client websites do not consistently enforce Content Security Policy headers, HSTS, anti-clickjacking headers, or strict referrer policy.

Rate limiting is implemented for login pages and payment callback endpoints, but it is not a standard baseline for all APIs.

Cookie notices are implemented on marketing websites, but client portals do not consistently provide a detailed cookie notice or preference management.

Website change detection is not enabled for all websites that process personal data. Unauthorized content changes may be detected through client reports instead of automated monitoring.

WebLine does not operate a formal vulnerability disclosure program for external security researchers.

7. Vulnerability, Patch, and Penetration Testing Policy

Dependency scanning is performed monthly for active production repositories.

Critical vulnerabilities on internet-facing production systems must be remediated within 15 calendar days. High vulnerabilities must be remediated within 30 calendar days.

Patch exceptions require a risk acceptance ticket and approval from the system owner.

Container base images are updated during monthly maintenance windows when client availability requirements allow.

Internal vulnerability scans are performed ad hoc before major launches but are not scheduled for all environments.

The last independent penetration test covered only one ecommerce application in 2024. WebLine has not performed annual independent penetration testing across the production portfolio.

Some accepted vulnerabilities remain open for more than 90 days because exception tickets do not always include expiry dates.

8. Logging, Monitoring, and Security Event Management Policy

Identity provider logs, cloud audit logs, firewall logs, endpoint protection alerts, CI/CD audit events, and production application error logs are forwarded to a centralized logging platform.

Alerts are configured for repeated failed logins, disabled MFA, cloud root-account usage, production deployment outside maintenance windows, malware detection, and changes to DNS records.

Critical security logs are retained online for 90 days and archived for 180 days.

Privileged actions in cloud consoles are logged. Privileged actions inside some client CMS admin panels are not consistently logged or reviewed.

Log review is performed weekly for production cloud alerts. Project-level application logs are reviewed only after incidents or client complaints.

Container time synchronization is inherited from the hosting platform, but WebLine does not independently verify time synchronization across all containers and serverless functions.

9. Incident Response and Breach Management Policy

WebLine maintains an incident response plan with severity levels, escalation contacts, internal communication channels, client notification owner, and decision authority.

Security incidents must be reported to the Head of Engineering within 24 hours of discovery.

High-severity incidents involving production client systems must be escalated to the General Manager and affected Project Manager.

The incident response team records incident timelines, affected assets, root cause, containment actions, recovery actions, and lessons learned.

WebLine has not defined a formal digital forensics evidence-handling procedure, chain-of-custody template, or external forensic retainer.

The breach notification procedure does not define specific PDPL notification triggers, competent authority notification steps, or data subject notification timeframes.

The last incident response tabletop exercise was completed more than eighteen months ago.

10. Privacy and Saudi PDPL Policy

WebLine publishes a privacy notice for its own website and client support portal. The notice explains the categories of personal data collected, common processing purposes, and a contact email for privacy requests.

Marketing email consent is captured through an opt-in checkbox. Users may unsubscribe from marketing messages.

Data subject requests are received by email and tracked manually by the support team.

WebLine has not defined a formal statutory response SLA for data subject access, correction, deletion, or portability requests.

WebLine has not completed a full record of processing activities for all client projects, analytics tools, logs, cookie technologies, and support workflows.

Data protection impact assessments are not performed before launching new features that process sensitive or high-volume personal data.

Personal data is transferred to cloud hosting regions and analytics providers outside the Kingdom for some client projects. WebLine does not consistently document the legal basis, transfer assessment, client approval, or Article 29 conditions for each cross-border transfer.

Retention rules are defined for production databases and backups, but old analytics exports, support attachments, and project handover folders do not have enforced retention or destruction dates.

Processor contracts include confidentiality clauses for major hosting providers, but two analytics providers do not yet have signed data processing addenda.

11. Cloud, Third-Party, and Outsourcing Security Policy

Cloud services must be approved by the Head of Engineering and DevOps Lead before production use.

Production cloud infrastructure is deployed using infrastructure as code where possible. Production secrets are stored in a managed secrets service.

Client contracts include confidentiality, incident notification, access control, and right-to-audit language where the client template permits it.

Vendors that process client confidential information complete a security questionnaire before onboarding.

WebLine does not perform periodic security reassessments for all active vendors after onboarding.

A cloud configuration baseline exists for the primary cloud account, but it is not fully applied to all client-dedicated accounts.

WebLine does not use continuous cloud security posture management across all accounts.

Exit plans are not documented for all hosting, CDN, analytics, and managed database providers.

12. Cryptography and Email Protection Policy

Sensitive data in transit must use TLS 1.2 or higher. Production databases and backups containing client confidential information or personal data must use AES-256 or equivalent managed encryption.

Production secrets must be stored in the approved secrets manager. Key rotation is required annually and immediately after suspected exposure.

WebLine has not created a locally approved cryptographic algorithm catalogue or mapped its encryption requirements to Saudi national cryptographic requirements.

SPF and DKIM are enabled for the corporate email domain.

DMARC is configured in monitoring mode only. The corporate domain does not yet enforce a quarantine or reject policy.

Mailbox forwarding rules are reviewed after account compromise events but are not reviewed periodically.

13. Backup, Recovery, and Business Continuity Policy

Production databases are backed up daily. Source code repositories are replicated by the hosting provider and protected with organization-level access controls.

Backups containing personal data or client confidential data are encrypted and stored separately from the production environment.

Restore tests are performed quarterly for the highest criticality production client applications.

Recovery Time Objective and Recovery Point Objective values are documented for the top five revenue-critical applications.

Business continuity plans do not fully cover corporate SaaS tools, design platforms, project management systems, or the full development toolchain.

Staging environments are not included in the formal recovery scope.

14. Human Resources, Awareness, and Remote Work Policy

All employees sign confidentiality terms and acceptable use requirements during onboarding.

New employees complete cybersecurity awareness training during onboarding. Annual awareness training is assigned to all employees.

Privileged users receive additional administrative security guidance from the DevOps Lead.

Secure coding training completion for developers is currently 60 percent and is not enforced before assigning developers to client projects.

Background screening is performed for full-time employees before hiring. Contractor screening is not consistently completed for short-term development engagements.

Remote access to production systems requires VPN or approved cloud SSO. Company-managed laptops use disk encryption and endpoint protection.

BYOD is allowed for designers working on mockups and client content. Some personal devices are not enrolled in mobile device management.

15. Physical Security and Endpoint Protection Policy

WebLine uses a managed office and co-working space. Employees use badges to access the office area.

Visitors must be escorted in the office area when client confidential information is displayed or discussed.

Company laptops use full disk encryption, endpoint protection, screen lock, and remote wipe where supported.

USB storage is blocked by default on managed developer laptops.

Co-working facility access logs are not reviewed by WebLine security or management.

USB exceptions for client file transfer are approved by team leads, but exception records are not always retained.

Appendix A. Governance Evidence and Current Exceptions

The Head of Engineering maintains quarterly security status notes covering open risks, high-risk deployments, overdue vulnerabilities, access review completion, and incidents. These notes are shared with the General Manager and project leadership.

The risk register includes production application risks, client hosting risks, third-party risks, privacy risks, cloud configuration risks, and selected operational risks. Each entry includes a risk owner, likelihood, impact, current treatment decision, and target date.

Risk treatment decisions are currently approved by the Head of Engineering. WebLine has not documented formal approval thresholds for accepting high or critical cybersecurity risks.

Security policy exceptions are tracked in the service desk when raised by engineering teams. Exceptions are not consistently assigned expiry dates, documented compensating controls, or a named business owner.

The company has not completed an independent cybersecurity audit in the last twelve months. Internal reviews are performed by the same engineering team that owns several controls.

A future governance improvement is to approve risk appetite, risk tolerance thresholds, and exception acceptance rules through executive management before client onboarding for regulated projects.

Appendix B. Application Security Implementation Notes

For active production repositories, every change must pass peer review, build validation, dependency scan, and deployment approval before release. The CI/CD pipeline records build logs and deployment history.

Developers must use server-side validation for user input, parameterized queries or approved ORM patterns for database access, and framework-provided output encoding for rendered content.

Session cookies for new applications must use Secure and HttpOnly attributes. SameSite is configured on new authentication projects, but older client portals have not been fully remediated.

WebLine requires TLS for public websites and APIs. Legacy client websites do not consistently enforce HSTS, Content Security Policy, anti-clickjacking headers, or strict referrer policy.

Threat modeling is documented for ecommerce, authentication, payment, and high-volume personal data projects. Smaller websites and internal admin portals are usually reviewed through checklist comments only.

Dynamic application security testing is recommended before major releases but is not mandatory for every production deployment. OWASP ASVS is referenced by senior developers but is not yet a formal acceptance baseline.

Emergency fixes can be approved in Slack during outages. Some emergency changes are missing formal post-implementation review notes and rollback evidence.

Appendix C. Identity and Privileged Access Notes

Named accounts are required for employees, contractors, and service accounts. New production access requires manager approval and system owner approval before provisioning.

Multi-factor authentication is enforced for source code repositories, cloud consoles, password vaults, VPN access, CI/CD administration, and production CMS administrator accounts.

Privileged access to production cloud accounts is limited to DevOps engineers. The DevOps Lead reviews privileged cloud access quarterly and removes unneeded permissions.

The legacy staging CMS platform still uses a shared administrator account named webline-stage-admin. The account is limited to staging environments but does not provide individual accountability.

Contractor deprovisioning is managed through service desk tickets. The target is removal within ten business days after contract end, but WebLine does not consistently measure actual completion time.

Annual access review is performed for non-critical SaaS tools. Some analytics, design, AI coding, and project management tools are not included in the quarterly production access review.

Password rules block common passwords and require at least 10 characters. The password standard has not been upgraded to require at least 12 characters across all systems.

Appendix D. Personal Data and Privacy Processing Notes

WebLine processes business contact data, support messages, website account data, IP addresses, cookie identifiers, application logs, limited payment metadata, and client content when operating managed web platforms.

A privacy notice is available on WebLine's website and support portal. The notice explains common purposes and provides a privacy contact email.

Data subject requests are tracked manually through support tickets. WebLine has not defined a formal statutory response SLA for access, correction, deletion, objection, or portability requests.

The record of processing activities is complete for the support portal and corporate website. It is incomplete for analytics tools, project-specific databases, application logs, cookie technologies, and historical client projects.

Personal data is transferred to cloud hosting regions and analytics providers outside the Kingdom for selected projects. Transfer basis, client approval, and Article 29 assessment evidence are not consistently documented.

Data protection impact assessments are not required before every feature that processes sensitive or high-volume personal data. Project teams decide whether a privacy review is needed.

Retention periods are defined for production databases and backups. Old analytics exports, support attachments, and project handover folders do not have enforced destruction dates.

Appendix E. Logging, Monitoring, and Incident Handling Notes

Identity provider logs, cloud audit logs, firewall logs, endpoint alerts, deployment events, DNS changes, and production application error logs are forwarded to the centralized logging platform.

Configured alerts cover repeated failed logins, disabled MFA, root-account usage, suspicious VPN activity, production deployment outside maintenance windows, malware detection, and security tool tampering.

Critical security logs are retained online for 90 days and archived for 180 days. WebLine has not approved a one-year retention requirement for all critical cybersecurity event logs.

Privileged actions in cloud consoles are logged and reviewed after alerts. Privileged actions inside selected legacy CMS admin panels are not consistently logged or reviewed.

The incident response plan defines severity levels, escalation contacts, communication channels, client notification owner, and decision authority.

The incident record template captures timeline, affected assets, suspected root cause, containment steps, recovery actions, and lessons learned.

WebLine has not defined a formal digital forensics evidence-handling procedure, chain-of-custody template, or external forensic retainer. The PDPL breach notification procedure also lacks specific authority notification steps and data subject notification timing.

Appendix F. Cloud, Vendor, and Outsourcing Notes

Cloud services require approval from the Head of Engineering and DevOps Lead before production use. Production secrets must be stored in the approved secrets manager.

Infrastructure as code is used for the primary cloud account and major ecommerce platforms. Some older client-dedicated accounts were created manually and do not fully match the baseline.

The primary cloud baseline includes MFA, restricted root account usage, encrypted storage, centralized logging, private database networks, security groups, and daily database backups.

Continuous cloud security posture monitoring is not enabled across all accounts. Configuration drift may be detected during monthly checks or during incident investigation.

Vendors handling client confidential data complete a security questionnaire before onboarding. Major hosting and payment vendors have confidentiality and incident notification clauses.

Two analytics providers do not yet have signed data processing addenda. Periodic reassessment is not performed for every active vendor after onboarding.

Exit plans are not documented for all hosting, CDN, managed database, analytics, email, and project management providers. Client handover procedures vary by project manager.

Appendix G. Resilience, Backup, and Recovery Notes

Production databases are backed up daily. Backups containing client confidential information or personal data are encrypted and stored separately from production environments.

The highest criticality production applications have documented Recovery Time Objective and Recovery Point Objective values. The top five revenue-critical applications are reviewed quarterly.

Restore tests are performed quarterly for the highest criticality production client applications. Restore testing is not consistently performed for lower criticality client websites.

Source code repositories are replicated by the hosting provider and protected by organization-level access controls, branch protection, and MFA.

Business continuity plans cover production application recovery and client communication for major outages. Corporate SaaS tools, design platforms, project management systems, and the full development toolchain are not fully covered.

Staging environments are not included in formal recovery scope. WebLine accepts that staging rebuild may take longer than production recovery.

Backup restore evidence is stored in the service desk. Some restore test records include screenshots but do not include complete validation steps or application owner signoff.

Appendix H. Workforce, Endpoint, and Physical Security Notes

Employees sign confidentiality terms, acceptable use requirements, and information handling obligations during onboarding. Contractor onboarding requirements are defined by project managers.

Cybersecurity awareness training is assigned during onboarding and annually. Completion is tracked for employees, but contractor completion is not consistently tracked for short-term engagements.

Secure coding training completion for developers is currently 60 percent. WebLine has not made secure coding training a prerequisite before assigning developers to client projects.

Company-managed laptops use disk encryption, endpoint protection, screen lock, and remote wipe where supported. USB storage is blocked by default on managed developer laptops.

BYOD is allowed for designers working on mockups and client content. Some personal devices are not enrolled in mobile device management and do not receive centralized security configuration.

WebLine uses a managed office and co-working space. Employees use badges to access the office area and visitors are escorted when client confidential information is displayed or discussed.

Co-working facility access logs are not reviewed by WebLine security or management. USB exception records for client file transfer are not always retained.